MODULE 22 · DOMAIN 5 - INCIDENT AND EVENT RESPONSE

Automated Remediation

AWS Config rules, recording and remediation, conformance packs and aggregators, OpsCenter, chat operations, and AI-assisted investigation.

DOMAIN 5 of 6 EXAM WEIGHT 14% MODULE 22 of 34

admin@sthithapragna.com

Detect, decide, fix, record. Automation handles **decide** and **fix**, but only for problems you already **understand**.

Detection paired with a fix

DETECTED BY	TYPICAL FIX
AWS Config rule, non-compliant resource	Config remediation running an Automation runbook
EventBridge event, such as an API call	A rule targeting a runbook, Lambda or Step Functions
CloudWatch alarm	An alarm action: runbook, Lambda, Auto Scaling, EC2
Security finding	EventBridge, or Security Hub automation (module 27)

ON THE EXAM

Config answers 'is this resource out of policy'. EventBridge answers 'did something just happen'.

AWS Config, in one slide

- The **configuration recorder** captures a configuration item whenever a supported resource changes.
- Each resource gets a **timeline**: what it looked like, when it changed, and who changed it via CloudTrail.
- **Rules** evaluate resources and mark them compliant or non-compliant.
- Findings and compliance changes are events, so EventBridge can act on them too.

> ON THE EXAM
>
> 'What did this security group look like last Tuesday, and who changed it?': Config's resource timeline.

Config rules

CHOICE	OPTIONS
Rule type	AWS managed; custom Lambda; custom policy written in Guard
Trigger	On configuration change; periodic, such as every 24 hours
Evaluation mode	Detective: existing resources; proactive: before deployment
Scope	Resource types, tags, or specific resources

ON THE EXAM

Use a managed rule when one exists. A custom Guard policy avoids writing and running a Lambda function.

Recording: what, and how often

- Record all resource types, or include or exclude specific ones.
- **Continuous** recording captures every change; **daily periodic** recording captures one state a day.
- Periodic recording cuts cost for resources that change constantly, such as short-lived instances.
- Record global resources, such as IAM, in one Region only, or you pay for duplicates.

> ON THE EXAM
>
> Config costs rising from churning resources, and daily state is enough: periodic recording for those types.

Config remediation

- A remediation action is a Systems Manager **Automation runbook**, such as AWS-DisablePublicAccessForSecurityGroup.
- **Manual** remediation waits for a person to click; **automatic** runs on every non-compliant evaluation.
- Automatic remediation retries a set number of times, within a time window.
- The runbook runs as an **AutomationAssumeRole**, which needs permission for everything it changes.

> ON THE EXAM
>
> Remediation 'fails with access denied': the assume role lacks permissions, or does not trust Systems Manager.

Automatic remediation, in a template

```
1  Type: AWS::Config::RemediationConfiguration
2  Properties:
3    ConfigRuleName: restricted-ssh
4    TargetType: SSM_DOCUMENT
5    TargetId: AWS-DisablePublicAccessForSecurityGroup
6    Automatic: true
7    MaximumAutomaticAttempts: 3
8    RetryAttemptSeconds: 60
9    Parameters:
10     GroupId: { ResourceValue: { Value: RESOURCE_ID } }
11     AutomationAssumeRole: { StaticValue: { Values: [ !GetAtt RemediationRole.Arn ] } }
```

10 The non-compliant security group's ID is passed in automatically.

11 The role the runbook runs as. Missing permissions here cause failures.

ON THE EXAM

Deploy the rule and its remediation together, as code, then roll out across accounts with a conformance pack.

Conformance packs

- A **conformance pack** bundles rules and remediations into one deployable template.
- Sample packs map to frameworks, such as operational best practices for CIS or PCI DSS.
- **Organisation conformance packs** deploy to every account from a delegated administrator.
- Each pack reports a compliance score across its rules.

> ON THE EXAM
>
> The same rules and fixes in every account, managed centrally: an organisation conformance pack.

Aggregators: one view of many accounts

- An **aggregator** gathers configuration and compliance data from many accounts and Regions.
- With Organizations, it covers every account automatically, including new ones.
- **Advanced queries** use SQL across the aggregated inventory.
- An aggregator views and queries. It does not deploy rules; conformance packs do that.

> ON THE EXAM
>
> Auditors want one view of compliance across 60 accounts and four Regions: an aggregator in the delegated admin account.

Fix automatically, or notify a person?

AUTOMATE THE FIX

Understood and reversible

- The cause and fix are well known
- Safe to apply without judgement
- Easy to reverse if wrong
- Examples: open SSH, public snapshot, missing tags

NOTIFY AND ASSIST

Ambiguous or risky

- The cause needs investigating
- The fix could cause an outage
- Hard to reverse, such as deleting
- Examples: error spikes, cost anomalies, data loss

THE TIEBREAKER

Auto-remediation that deletes data or restarts production on a guess is a second incident waiting to happen.

OpsCenter

- **OpsItems** collect operational issues from alarms, Config, EventBridge and AWS Health in one place.
- Each OpsItem shows related resources, recent changes, and suggested runbooks to run from it.
- Similar OpsItems are deduplicated, so a flapping alarm does not create hundreds.
- Works across accounts, with a delegated administrator.

> ON THE EXAM
>
> One place to track operational issues and run fixes from them, without a separate ticketing tool: OpsCenter.

The catalogue has moved: incident tooling

SERVICE	STATUS
Systems Manager Incident Manager	Closed to new customers, 7 Nov 2025
AWS Chatbot	Renamed Q Developer in chat applications, Feb 2025
CloudWatch investigations	Generally available June 2025, no extra cost
CloudWatch incident reports	Five Whys analysis added, Nov 2025
AWS DevOps Agent	Preview Dec 2025; generally available Apr 2026

THE RULE

Incident Manager still appears in the exam guide. Answer on the guide's terms; know the reality.

Operations in chat

- **Amazon Q Developer in chat applications** posts notifications to Slack, Microsoft Teams and Chime.
- Notifications arrive through **SNS topics** mapped to channels: alarms, pipelines, Health, GuardDuty.
- Engineers can run commands and runbooks from the channel.
- A channel IAM role plus **guardrail policies** cap what anyone in the channel can do.

ON THE EXAM

Alarms and failures in the team's Slack channel, with safe commands, least effort: Q Developer in chat applications.

CloudWatch investigations

- An AI agent looks for anomalies, gathers related signals, and proposes **root-cause hypotheses**.
- Suggests remediation: Automation runbooks, re:Post articles, documentation.
- Starts from any CloudWatch widget, from chat, or **automatically from an alarm action**.
- Teams collaborate in the investigation, accepting or discarding findings.

> ON THE EXAM
>
> Start root-cause analysis automatically when a critical alarm fires, AWS-native, no code: an investigation alarm action.

An aside beyond the exam guide: AWS DevOps Agent

- Generally available April 2026: an autonomous agent that investigates incidents as they are raised.
- Builds a map of application resources, then correlates telemetry, deployments and code changes.
- Triggered by CloudWatch alarms or tickets; integrates with third-party observability and Git tools.
- Newer than the exam guide. It is unlikely to be a correct option, but it is where practice is heading.

> ON THE EXAM
>
> Use it at work; do not expect it on the exam. CloudWatch investigations is the likelier exam-era answer.

Closing the loop after an incident

01
Detect
Alarm, event, or Config rule.

›

02
Investigate
Humans, helped by investigations.

›

03
Fix
Runbook, rollback, or change.

›

04
Review
Incident report, Five Whys.

›

05
Prevent
New rule, alarm, test or remediation.

ON THE EXAM

Every incident that was investigated by hand should end with a new automated detection or fix.

> A company has 70 accounts in AWS Organizations. Security groups allowing SSH from 0.0.0.0/0 keep appearing, and must be closed automatically within minutes.
>
> Developers must still be able to change security groups for legitimate reasons. The company wants the least operational overhead.

Which solution meets these requirements?

A. A nightly Lambda function in each account that scans and fixes security groups

B. An organisation conformance pack with the restricted-ssh rule and automatic remediation using AWS-DisablePublicAccessForSecurityGroup

C. Enable GuardDuty in every account

D. An SCP that denies ec2:AuthorizeSecurityGroupIngress

◆ PAUSE AND DECIDE

Which solution meets these requirements?

A **Nightly Lambda**

Hours of exposure, not minutes, and custom code in 70 accounts.

B **Organisation conformance pack**

Managed rule plus AWS-owned runbook, deployed once to every account, fixing within minutes.

C **GuardDuty**

Detects threats. It does not close security groups.

D **SCP denying ingress changes**

Blocks every legitimate change too, which the scenario forbids.

THE SIGNAL

Known misconfiguration, fixed automatically, across an organisation: conformance pack with remediation.

> A Config rule flags S3 buckets without logging, with automatic remediation using an Automation runbook. The rule works, but every remediation fails with an AccessDenied error.
>
> The remediation configuration passes no AutomationAssumeRole parameter.

What should the DevOps engineer do?

A Add permissions to the AWS Config service-linked role

B Grant the engineer who created the rule more permissions

C Increase the maximum automatic remediation attempts

D Create a role trusting Systems Manager with the needed S3 permissions, and pass it as AutomationAssumeRole

◆ PAUSE AND DECIDE

What should the DevOps engineer do?

A Config service-linked role

Service-linked role permissions are managed by AWS, and the runbook does not run as it.

B Engineer's permissions

Remediation runs later, automatically, not as the person who created it.

C More attempts

Fails with AccessDenied more times.

D AutomationAssumeRole

The runbook needs its own role with the permissions it uses, trusting Systems Manager.

THE SIGNAL

Remediation fails with AccessDenied: the runbook's assume role is missing or under-privileged.

> Auditors need one view of Config rule compliance across 60 accounts in four Regions, including accounts added later. They also want to run SQL queries across the whole inventory.
>
> The company uses AWS Organizations and wants the least operational overhead.

What should the DevOps engineer set up?

A Give auditors read-only roles in every account and Region

B A Config aggregator using Organizations, in a delegated administrator account

C Athena queries over Config snapshots copied from each account

D An organisation conformance pack

◆ PAUSE AND DECIDE

What should the DevOps engineer set up?

A Roles everywhere

240 places to look. Not one view.

B Organisation aggregator

One view across all accounts and Regions, new accounts included, with SQL advanced queries.

C Athena over snapshots

A copying pipeline to build and maintain.

D Conformance pack

Deploys rules. Does not aggregate or query.

THE SIGNAL

Deploy rules everywhere: conformance pack. See and query them everywhere: aggregator.

> AWS Config costs have tripled. Development accounts run Auto Scaling groups that launch and terminate hundreds of instances daily, each change recorded continuously.
>
> Compliance teams only need a daily view of EC2 instances in development, but continuous recording for everything else.

What should the DevOps engineer do?

A Turn off Config in the development accounts

B Exclude EC2 instances from recording everywhere

C Delete the Config rules that evaluate EC2 instances

D Set daily periodic recording for EC2 instances in development, keeping continuous recording for other types

◆ PAUSE AND DECIDE

What should the DevOps engineer do?

A Turn off Config

Loses the daily view compliance needs, and everything else too.

B Exclude EC2 everywhere

Loses instance recording in production as well.

C Delete rules

Rules are not the cost here. Recording is.

D Periodic recording for dev instances

One state a day for the churning type; continuous elsewhere. Exactly the requirement.

THE SIGNAL

Config cost driven by churn, daily state sufficient: periodic recording for those resource types.

> An on-call team lives in Slack. It wants CloudWatch alarms, pipeline failures and AWS Health events posted to its incident channel.
>
> Engineers should be able to run safe, read-only diagnostic commands from the channel, and the setup should take the least effort.

What should the DevOps engineer set up?

A. Amazon Q Developer in chat applications, with SNS topics mapped to the channel and guardrail policies on its role

B. A Lambda function that posts every event to a Slack webhook

C. Email notifications to the channel's email address

D. An EventBridge API destination that posts events to a Slack webhook

◆ PAUSE AND DECIDE

What should the DevOps engineer set up?

A Q Developer in chat applications

Formatted notifications from SNS topics, plus commands limited by guardrail policies.

B Lambda to webhook

Custom formatting code, and no commands from the channel.

C Email to channel

Unformatted, and no commands.

D API destination to webhook

Delivers messages without code, but still no commands, and no formatting per service.

THE SIGNAL

Notifications plus safe commands in chat: Q Developer in chat applications, formerly AWS Chatbot.

> When a critical latency alarm fires, on-call engineers spend an hour correlating metrics, logs, deployments and configuration changes before forming a theory.
>
> The team wants AI-assisted root-cause hypotheses to start automatically when that alarm fires, using AWS-native tooling, with no code.

What should the DevOps engineer configure?

A. A Lambda function on the alarm that queries logs and emails a summary

B. A Contributor Insights rule on the application logs

C. An alarm action that starts a CloudWatch investigation

D. An Incident Manager response plan for the alarm

◆ PAUSE AND DECIDE

What should the DevOps engineer configure?

A Lambda summary

Custom code, and a summary is not correlation or hypotheses.

B Contributor Insights

Finds top contributors in logs. Does not correlate across signals.

C Investigation alarm action

Starts an AI investigation automatically: anomalies, related signals, hypotheses, suggested runbooks.

D Incident Manager

Closed to new customers since November 2025, and it coordinates response rather than finding causes.

THE SIGNAL

Automatic, AI-assisted root-cause hypotheses from an alarm, no code: a CloudWatch investigation.

Module 22 in five lines

- Detect, decide, fix, record. Automate fixes that are understood and reversible.
- Config: managed or Guard rules; periodic recording for churn; remediation needs an assume role.
- Conformance packs deploy rules everywhere; aggregators see and query them everywhere.
- OpsCenter tracks issues; Q Developer in chat applications brings alerts and commands to chat.
- Investigations propose root causes from an alarm. Incident Manager is closed to new customers.

> ON THE EXAM
>
> Next, module 23: troubleshooting failed deployments and operations, the last module of Domain 5.